

SWYNEX-Web-Security-Review

Defensive Web Security Review — Authorized Local Lab

Assessment target: 192.168.126.128 (Metasploitable2 / DVWA)

Date: 07 October 2026

Assessment type	Defensive web security review
Scope	Authorized local training VM only
Tools/evidence	Nmap, browser validation, screenshots
Applications	Apache HTTPD, Apache Tomcat 5.5, DVWA

1. Executive Summary

A security review was performed against the intentionally vulnerable Metasploitable2 training environment at 192.168.126.128. The review identified legacy web-server software, an exposed Tomcat service, and a reflected cross-site scripting (XSS) condition in DVWA. The XSS finding was validated in the browser with a harmless proof-of-concept alert. No third-party systems were targeted.

2. Key Findings

ID	Finding	Severity
WEB-01	Legacy Apache HTTP Server 2.2.8	High
WEB-02	Legacy Apache Tomcat 5.5 on TCP/8180	High
WEB-03	Reflected XSS in DVWA input	High
WEB-04	Multiple web/management surfaces exposed	Medium

3. Methodology

- Nmap service/version detection was used to identify reachable services.
- The HTTP landing page and Tomcat default page were reviewed for exposed applications and management surfaces.
- DVWA reflected XSS was validated with a harmless alert proof-of-concept.
- Findings were documented with evidence, impact, severity, and remediation.

4. Detailed Findings

WEB-01 — Legacy Apache HTTP Server 2.2.8 — High

Evidence: Nmap identified TCP/80 as open and reported Apache httpd 2.2.8 ((Ubuntu) DAV/2).

Impact: Legacy web-server software increases exposure to known security weaknesses.

Remediation: Upgrade to a supported Apache release, remove unnecessary modules/features, and apply security updates.

WEB-02 — Legacy Apache Tomcat 5.5 exposed on TCP/8180 — High

Evidence: Nmap reported Apache Tomcat/Coyote on TCP/8180. The browser displayed the Tomcat 5.5 default page with Status, Administration, and Manager links.

Impact: An exposed legacy application server and management surface increases attack surface.

Remediation: Upgrade Tomcat, restrict management interfaces, remove default/example applications, and enforce strong authentication.

WEB-03 — Reflected Cross-Site Scripting (XSS) in DVWA — High

Evidence: The supplied DVWA screenshot shows the Reflected XSS page with the harmless payload alert('XSS'). A second screenshot shows the resulting browser alert, confirming execution.

Impact: Reflected XSS can execute attacker-controlled JavaScript in a victim browser under the application origin.

Remediation: Use context-aware output encoding, safe DOM APIs, appropriate input validation, a restrictive CSP, and secure cookie attributes.

WEB-04 — Multiple web applications and management surfaces exposed — Medium

Evidence: The HTTP landing page exposes TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV; the Tomcat page exposes administration and manager entry points.

Impact: Each additional application increases attack surface.

Remediation: Disable/remove unnecessary applications and expose management interfaces only through a protected administrative network or VPN.

5. Evidence

Figure 1 — Nmap service/version discovery

```
thaila@kali:~$ nmap -sV -p 80,443,8080,8180 192.168.126.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 02:34 -0400
Nmap scan report for 192.168.126.128
Host is up (0.00081s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
443/tcp   closed https
8080/tcp   closed http-proxy
8180/tcp   open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:61:54:86 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.34 seconds
```

Figure 2 — Metasploitable2 web landing page

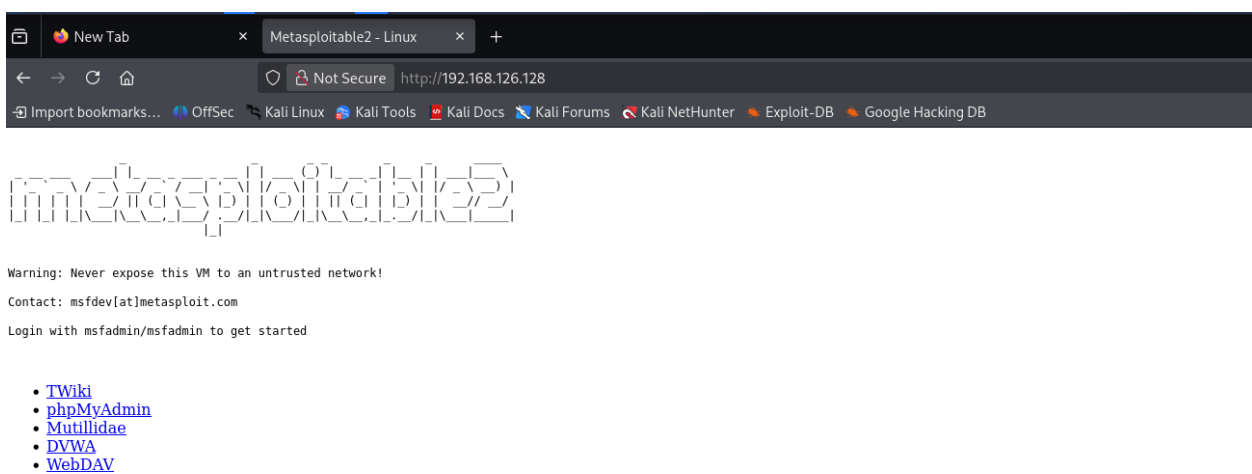


Figure 3 — Apache Tomcat 5.5 default page on TCP/8180

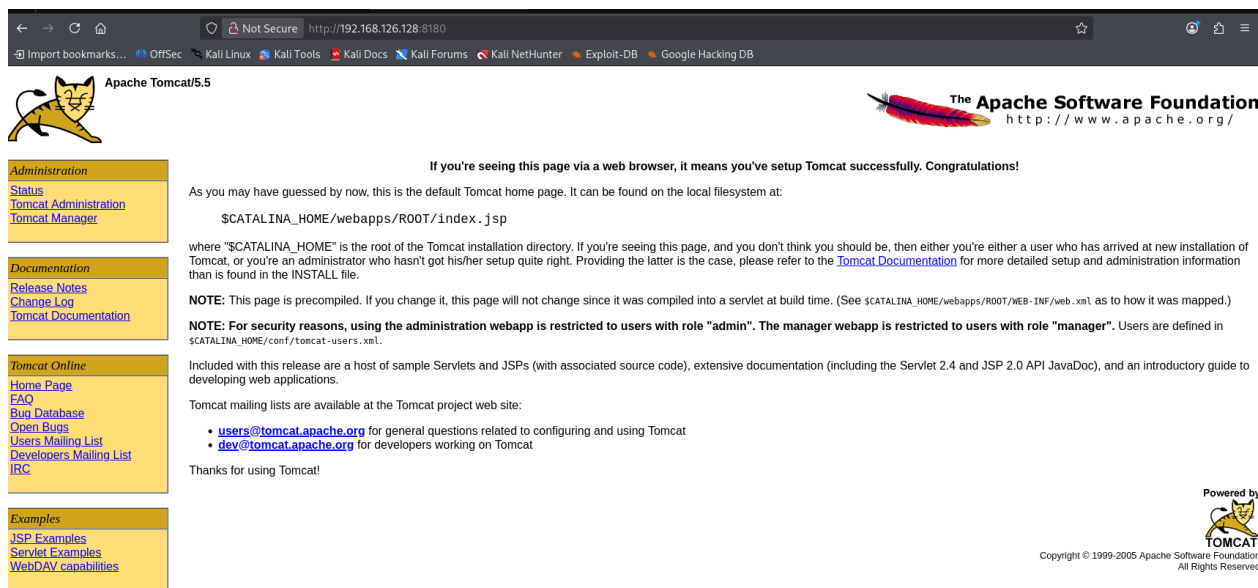


Figure 4 — DVWA reflected XSS page with harmless payload

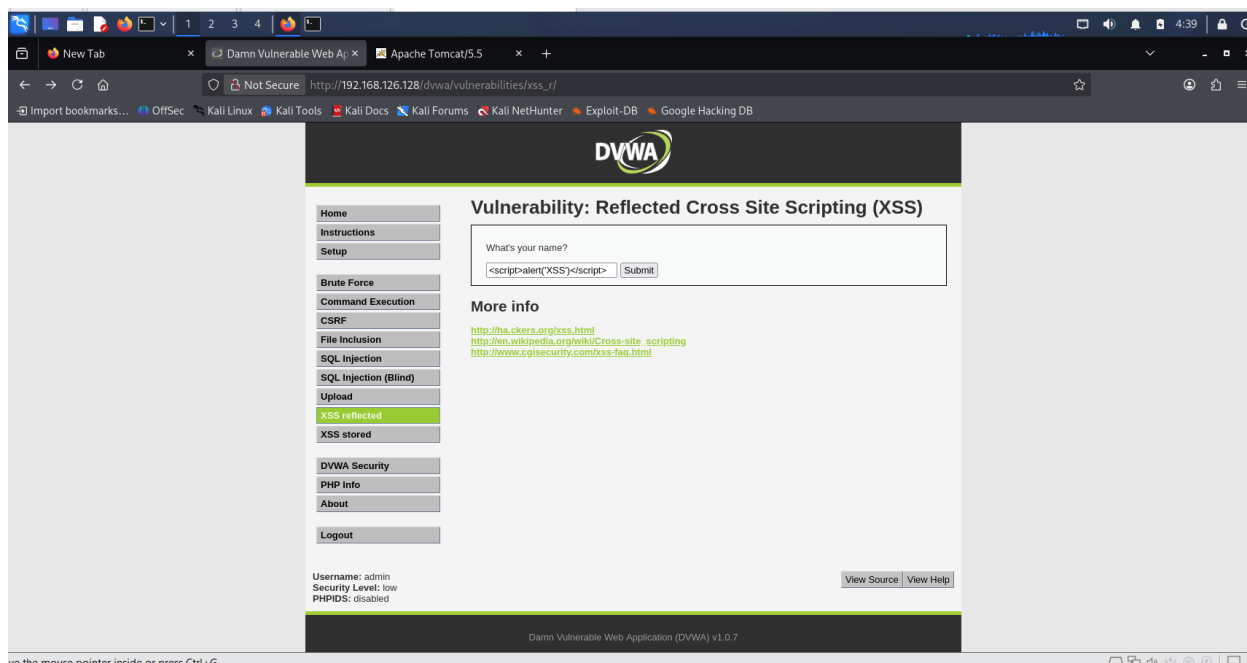
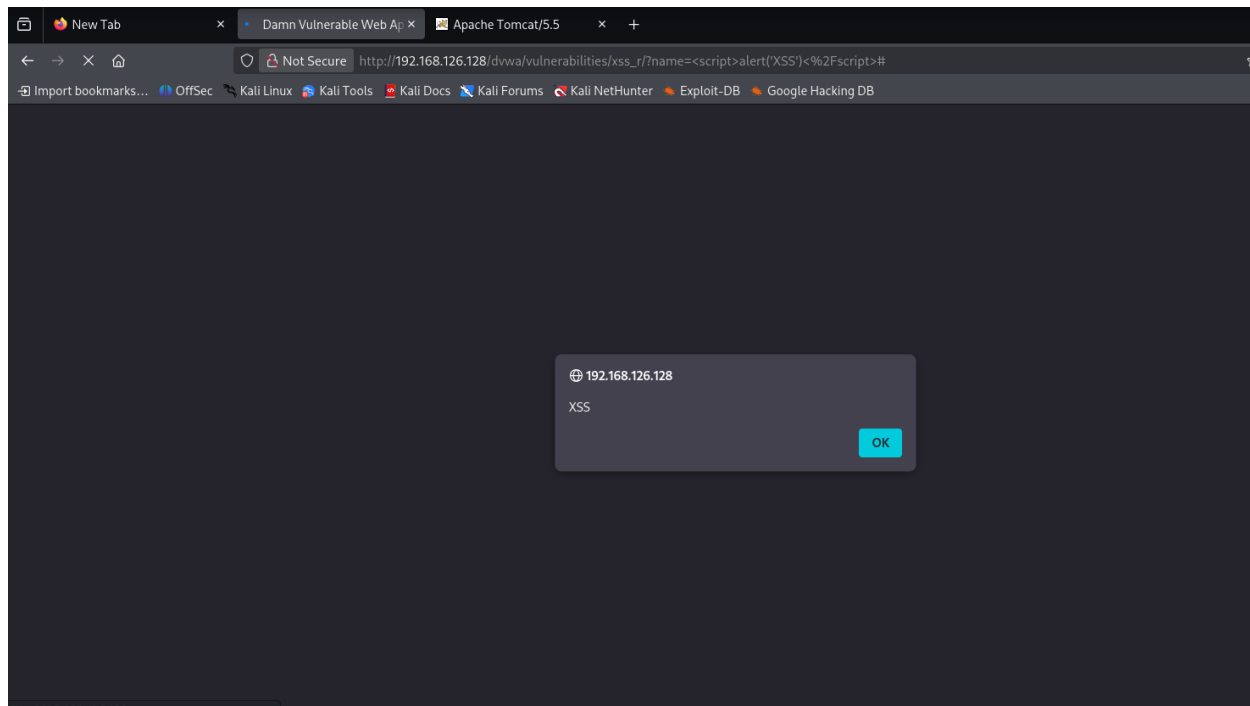


Figure 5 — DVWA reflected XSS proof-of-concept execution



6. Recommended Remediation Plan

1. Immediately isolate the training VM from untrusted networks.
2. Upgrade or retire Apache 2.2.8 and Tomcat 5.5; use supported releases.
3. Restrict Tomcat administration/manager endpoints to trusted administrators.
4. Remove default/example applications and unnecessary services.
5. Fix XSS through context-aware output encoding and safe DOM practices.
6. Add a restrictive Content Security Policy and secure cookie attributes.
7. Repeat service discovery and application security testing after remediation.

7. Conclusion

The supplied screenshots demonstrate a defensive assessment of an intentionally vulnerable local web-security lab. The main priorities are supported software versions, attack-surface reduction, secure configuration, and robust output encoding. All observations in this report are limited to the authorized lab environment.